

BacktestLab — Improvement Report

Consolidated review recommendations: security, core logic, architecture, features & polish
Version 1.0 · July 15, 2026 · Repo: rajaksahdev/BB · Stack: FastAPI + Postgres + backtesting.py + React/TS

This report consolidates every improvement recommended during the project review, ordered by priority. Guiding principle: BacktestLab's brand is **honest backtests** — items that protect result accuracy and trust rank above new features. The v1 scope line from the original spec remains in force; anything that would materially extend the timeline is explicitly parked in the v2 section.

Top three actions

1) Rotate the leaked Render API key and Postgres password (secrets remain in git history). **2)** Fix DCA forced-exit trade labeling — it currently distorts win-rate stats. **3)** Ship shareable read-only result links — the highest-leverage growth feature available.

1. Security — Do First (Urgent)

Leaked credentials are still live. `.claude/settings.local.json` was git-tracked and pushed to GitHub containing a Render API key and the production Postgres connection string with password. The file was removed from tracking and gitignored, but the secrets remain in git history — anyone who cloned or crawled the repo has them.

- **Rotate now:** the Render API key and the Postgres password. Treat the old values as burned.
- **History:** optionally rewrite with `git filter-repo`; simpler is to accept history as compromised and ensure new secrets never enter the repo.
- **Prevention:** add a pre-commit secret scanner (gitleaks) plus a CI secret-scan step so this class of leak cannot recur.

2. Review Focus Points — Verdicts

2.1 RSI flat-window → 50 convention

Defensible (the division-by-zero case is genuinely ambiguous; libraries vary between NaN and 50). **Keep it, but document it in the assumptions payload** so users comparing against TradingView understand small early-window differences.

2.2 The validate() hook design

Good pattern. Two refinements: (a) return a machine-readable **field name** alongside the message so the frontend can highlight the offending slider, not just show text; (b) add validators to the other strategies too — grid spacing vs. range, Bollinger num_std extremes — not just MA crossover.

2.3 finalize_trades=True and DCA (honesty bug)

A DCA run's final forced exit is a single artificial trade that can dominate win rate, average trade %, and profit factor. **Fix:** flag force-closed trades in the trade list (e.g. `exit_reason: "end_of_data"`) and either exclude them from win-rate-style stats or footnote the result ("includes 1 position closed at end of period"). For DCA specifically, consider hiding win rate entirely via META — it is arguably meaningless for that strategy.

2.4 Optional fields for legacy saved rows

The current approach (optional TypeScript fields + hidden "More metrics" section) is correct. Do not backfill old rows; a migration is not worth it.

2.5 Exact-set assertion in the strategy catalog test

Intentionally brittle — **keep it**. Forcing a test edit when adding a strategy is a feature: it makes the parametrized run-test coverage explicit. Add a comment in the test stating this is deliberate, or a future contributor will "fix" it to a superset check.

3. Core Logic & Architecture

3.1 Verify next-bar execution (look-ahead bias)

backtesting.py defaults to filling orders at the **next** bar's open (`trade_on_close=False`) — confirm this has not been overridden. This is the single most important honesty property of the product. Add a dedicated regression test with a hand-computed 5-candle fixture proving fills occur at bar N+1's open.

3.2 ensure_fresh() in the request hot path

Per-request freshness fetching contradicts the original design rule ("never fetch live per backtest"): it adds Binance latency and failure modes into the user's hot path, and N concurrent runs on a stale pair can stampede fetches.

- Add a staleness tolerance — serve directly if the newest candle is under ~2 intervals old.
- Add a per-pair in-process lock so only one fetch runs at a time.
- Add a Render cron job for the nightly top-up so `ensure_fresh()` becomes a rare fallback, not the mechanism.

3.3 CPU-bound sync backtests on FastAPI

A few concurrent long backtests will contend on the GIL and stall sibling requests (including `/health`). Cheap mitigation now: a semaphore capping concurrent engine runs, returning 429 "busy, retry shortly" beyond the cap — far cheaper than a job queue and protects availability. Defer the real queue until measured latency hurts, per the original spec.

3.4 Billing webhook hardening

- **Idempotency:** store processed Lemon Squeezy event IDs — webhook retries must not double-apply.
- **Coverage:** handle `subscription_payment_failed` and `subscription_updated`, not only `created/expired` — otherwise a failed renewal leaves a user on Pro until expiry fires.

3.5 Observability

- Extend `/health` with data freshness (newest candle age per pair) to catch a broken backfill before users do.
- Log strategy/pair/params per run (never IPs/PII) — this is the product-analytics signal for choosing v2 features.

4. Highest-Leverage Feature Additions

4.1 Shareable read-only result links (growth engine)

Persist a public token for a saved backtest and render a branded, read-only result view. Traders pasting links in Discord/Telegram is free acquisition — every share is an ad. **Cheaper starter variant:** encode the config in the URL querystring so a clicked link lands in the lab pre-filled, one click from running.

4.2 Out-of-sample split toggle (overfitting teacher)

"Train on first 70%, test on last 30%" is two engine runs plus one UI toggle. If parameters shine in-sample and collapse out-of-sample, the user just learned the strategy is overfit — the most valuable lesson the tool can teach, and a strong Pro-tier feature.

4.3 Plain-English verdict line

Above the stat cards: "Beat buy-and-hold by 12% with lower drawdown" or "Underperformed simply holding."
Buy-and-hold is already computed — this is string formatting that converts numbers into the decision users pay for.

4.4 PNG chart export

lightweight-charts provides `takeScreenshot()` — pairs with share links and covers the FR-09 export requirement cheaply.

5. Smaller Polish Items

- Show "X saves remaining" near the Save button pre-emptively, instead of surfacing the limit only as a 402 failure — turns a frustration moment into an upgrade prompt.
- Persist the last-used config in `localStorage` so returning users don't start from defaults.
- Alembic-on-boot is fine at one instance; note in `render.yaml` that scaling to 2+ instances requires moving migrations to a release step (two containers racing upgrade head).

6. Parked for v2 (Good Ideas, Scope Creep Now)

- **Parameter sensitivity heatmap** — sweep parameters and show a grid of returns, revealing whether a result is a robust plateau or a lucky spike. Flagship Elite-tier candidate; N× compute + new UI surface.
- **Monte Carlo trade-shuffling** — drawdown confidence bands; fits the "AI optimization" tier story.
- **Walk-forward optimization, multi-pair portfolio backtests, short/leverage support** — valid expansion levers, all timeline-doublers.
- **Regime presets** largely shipped already via period buttons (2024/2025/YTD); extend with named bull/bear presets when convenient.

7. Consolidated Priority Matrix

Item	Priority	Effort	Why
Rotate leaked secrets + add secret scanning	P0 — Urgent	Hours	Credentials are public in git history; everything else waits.
DCA forced-exit trade labeling / stat exclusion	P0 — Honesty	~1 day	Distorted win rate in a product whose brand is honest results.
Next-bar execution regression test	P0 — Honesty	Hours	Guards the core anti-look-ahead property forever.
Webhook idempotency + payment_failed/updated events	P1	~1 day	Billing correctness; failed renewals must downgrade.
ensure_fresh(): tolerance + lock + nightly cron	P1	~1 day	Removes Binance from the hot path; prevents fetch stampedes.
Concurrency semaphore on engine runs	P1	Hours	Protects availability without a premature job queue.
Shareable result links (querystring first)	P1 — Growth	1–2 days	Primary organic acquisition channel.
Plain-English verdict line	P2	Hours	Converts stats into the decision users pay for.
Out-of-sample split toggle	P2	~2 days	Teaches overfitting; strong Pro-tier feature.
PNG chart export	P2	Hours	Covers FR-09; pairs with sharing.
validate() field names + more strategy validators	P2	~1 day	Better UX; catches bad params across all strategies.
Health freshness + product-analytics logging	P2	Hours	Catch pipeline breaks early; data for v2 decisions.
Saves-remaining indicator, localStorage config	P3	Hours	Conversion + returning-user quality of life.
Migration note for multi-instance scaling	P3	Minutes	Documentation guardrail for future scaling.